

Cybersecurity: Strategies and Best Practices

Introduction

Cybersecurity refers to the procedure of safeguarding vital infrastructure and sensitive data against cyber-attacks. Cybersecurity measures, often known as information technology (IT) security, are intended to protect networking systems and applications from both within and outside a corporation.

In 2020, the average data breach cost will be USD 3.86 million globally and USD 8.64 million in the US. These expenses include the price of discovering and responding to the breach, downtime and lost income, and long-term adverse publicity to a company's brand. Cybercriminals target clients' Personally Identifiable Information (PII), including names, addresses, national identity numbers (such as Social Security numbers in the United States, and fiscal codes in Italy), and credit card information, which they then sell to shadowy online black markets. Customer trust is frequently lost as a result of compromised PII, which can result in regulatory fines and even legal action.

So, the significance of cybersecurity and its strategies and best practices bears unavoidable attention. In this course, we will dive into various aspects of cybersecurity and its best practices.

Module One: Security Architecture

Lesson-01: What Is a Cyber Security Architecture?

Cybersecurity architecture, also defined as "network security architecture," is a framework that defines the organizational structure, standards, regulations, and functional behavior of a computer network, taking into account both security and network elements. The arrangement, coordination, and integration of numerous components of your computer or cyber system are known as cybersecurity architecture.

The overall architecture of a system includes a cybersecurity architectural framework. It was developed and constructed to aid in system or product overall design.

A security architect is someone who foresees prospective cyber threats and designs structures and systems to protect against them. Most businesses are vulnerable to cyberattacks, but a cybersecurity architecture plan may help you implement and monitor your network security systems. A cybersecurity architecture framework describes how all of your security policies relate to your overall system architecture and how they protect you from dangerous actors.

Firewalls, antivirus programs, and intrusion detection systems are all important components of cybersecurity methods for defending your company from external attacks. Your organization should develop a complete security architecture incorporating these diverse parts for your networks to maintain and maximize these security technologies as well as currently existing and working rules and processes.

Cybersecurity: Strategies and Best Practices

The strength of an organization's organizational structure is critical to its success. Important executives with commercial expertise, an effective workforce, and a strong business plan are all necessary. Establishing a strong cybersecurity architecture is no easy task; what makes a successful team is the consistency and dedication of all of the aforementioned individuals.

Lesson-02: Data Protection

Data protection is the process of preventing vital data from being corrupted, compromised, or lost, as well as giving the ability to restore the data to its original condition if it becomes inaccessible or unusable.

Data protection ensures that data is not corrupted, is only available for allowed reasons, and meets all legal and regulatory standards. When needed, protected data should be accessible and used for its intended purpose. On the other hand, data protection encompasses aspects such as data immutability, protection, and deletion/destruction in addition to data availability and readability.

What Are Data Protection Principles and How Do They Work?

Data protection principles help to safeguard data and make it accessible in any situation. It includes features of data management and data availability, as well as operational data backup and business continuity/disaster recovery (BCDR).

For data security, here are several key data management considerations:

Data availability ensures that users can access and use the data they need to do their jobs, even if it is lost or corrupted. Automating the transportation of vital data to offline and online storage is part of data lifecycle management. Information lifecycle management entails valuing, classifying, and protecting information assets from a variety of threats, including outages and disturbances at facilities, application and user errors, equipment failure, and malware and virus attacks.

Some of the most often used practices and technologies are as follows:

1. Data discovery is the initial step in data security, and it entails determining which data sets exist in the organization, which are business vital, and which contain sensitive data that may be subject to compliance rules.
2. Data loss prevention (DLP) is a set of tactics and technologies for preventing data from being stolen, lost, or destroyed by accident. Several technologies to protect against and recover from data loss are frequently included in data loss prevention solutions.
3. Storage with built-in data protection—modern storage technology has disk clustering and redundancy as standard features. For instance, Cloudian's Hyperstore enables low-cost storage of enormous volumes of data, rapid access for low RTO/RPO, and durability up to 14 nines.
4. Backup—makes copies of data and stores them independently, allowing for data restoration in the event of loss or alteration. Backups are a critical approach for ensuring

Cybersecurity: Strategies and Best Practices

business continuity when original data is lost, destroyed, or damaged by accident or on purpose.

5. Snapshots—like a backup, a snapshot is a complete image of a protected system, containing data and system files. A complete system can be restored to a specific moment in time using a snapshot.
6. Replication is a mechanism for replicating data from a secured system to another location on a regular basis. This creates a live, up-to-date replica of the data, allowing not just data recovery but also fast failover to the copy in the event that the primary system fails.
7. Firewalls are tools for monitoring and filtering network traffic. Only authorized users should be able to access or move data, which can be ensured through firewalls.
8. Authentication and authorization—controls that aid in verifying credentials and properly applying user privileges. In an identity and access management (IAM) solution, these controls are frequently used in conjunction with role-based access controls (RBAC).
9. Encryption modifies data content using an algorithm that can only be undone with the correct encryption key. Even if your data is taken, encryption protects it against unauthorized access by rendering it unreadable.
10. Endpoint protection safeguards your network's entry points, such as ports, routers, and connected devices. Endpoint protection software normally allows you to monitor and filter traffic at the network perimeter as needed.
11. Data erasure reduces responsibility by erasing information that is no longer required. This can be done after the data has been processed and analyzed, or it can be done on a regular basis when the data is no longer useful. Many compliance regulations, such as GDPR, require the erasure of redundant data.
12. A set of policies and technology that define how an organization responds to a disaster, such as a cyber assault, a natural disaster, or a large-scale equipment failure. Setting up a remote disaster recovery site with copies of protected systems and switching activities to those systems in the event of a disaster is characteristic of the disaster recovery procedure.

Lesson-03: Cryptography

The method of transforming ordinary plain text into unintelligible language, and vice versa, is known as cryptography. It is a method of storing and transmitting data in a format that can only be read and processed by those who are authorized to do so. Cryptography can be used for user authentication as well as protecting data from theft or change. Cryptography used to be synonymous with encryption, but today it is mostly centered on mathematical theory and computer science practice.

Cryptography in the modern era is concerned with:

Confidentiality - No one can understand what you're saying. Information cannot be tampered with.

Cybersecurity: Strategies and Best Practices

Non-repudiation - The sender cannot later contradict his or her intentions in transmitting the material.

Authentication – Both the sender and the receiver can verify each other.

Many applications use cryptography, including financial transactions, computer passwords, and e-commerce transactions.

In general, there are three sorts of cryptographic procedures.

- ✓ Cryptography with symmetric keys
- ✓ Hash functions
- ✓ Cryptography based on public keys

Symmetric-key Cryptography: The sender and recipient have the same key. The sender encrypts plaintext and sends the cipher text to the receiver using this key. Conversely, the recipient decrypts the message and retrieves the plain text using the same key.

Public-Key Cryptography: In the previous 300-400 years, this has been the most groundbreaking thought. Two related keys (public and private keys) are utilized in public-key cryptography.

The public key can be freely transmitted, but the private key that goes with it must be kept secret. The public key is employed for encryption, while the private key is utilized for decryption.

Hash functions: The key for this algorithm is not used. The plain text is hashed using a fixed-length hash value, rendering the contents of the plain text unrecoverable. Hash algorithms are used by several operating systems to safeguard passwords.

Lesson-04: Network Design

Systems that focus on data transmission technology are known as networks. Network design, like other system design disciplines, begins with analysis, where requirements are developed and ends with implementation when the system (or relevant system component) is built. The goal of network design is to meet data communication requirements while keeping costs low. Depending on geographic factors and the nature of the data to be transmitted, the breadth of needs varies substantially from one network design project to the next.

Inter-organizational, organizational, and departmental network analyses are all possible. As a result, the requirements developed during the analysis may specify an inter-network connecting two or more organizations, an enterprise network connecting a single organization's divisions, or a departmental network tailored to specific divisional requirements. Inter-networks and enterprise networks frequently connect facilities that are hundreds or thousands of miles apart. The type of technology that must be utilized to support data transfer is frequently dictated by the distance between physical links.

A number of specifics should be incorporated into your network infrastructure design, such as:

- ✓ A simple-to-grasp network map.

Cybersecurity: Strategies and Best Practices

- ✓ The cabling's structure and arrangement necessitated
- ✓ The number, type, and location of all network devices.
- ✓ Your addressing scheme for IP addresses
- ✓ Your network security architecture and operations in detail

Module Two: Security Operation

Lesson-01: What Is a Cyber Security Operation?

Cyber security operations encompass the processes, technologies, and personnel involved in protecting an organization's digital assets from cyber threats. At the heart of these operations lies the Security Operation Center (SOC), a centralized department dedicated to monitoring, detecting, analyzing, and responding to cyber-attacks. The SOC employs a combination of skilled professionals, well-defined protocols, and advanced technologies to maintain a strong security posture.

The SOC plays a vital role in safeguarding critical data, infrastructure, and operations. It acts as a central hub for monitoring network activities, identifying potential security breaches, and taking proactive measures to mitigate risks. By constantly monitoring and analyzing incoming and outgoing traffic, the SOC can detect suspicious behavior and respond swiftly to potential threats.

Examples of cyber security operations services include firewalls, IDS/IPS, incident management, and incident response. When it comes to running and maintaining a network or system, experience is crucial.

Lesson-02: Incident Response

The actions necessary to get ready for, find, stop, and recover from a data breach are referred to as incident response (IR).

What exactly is an Incident Response Plan, and why do you require one?

An incident response plan is a document that specifies an organization's incident response protocols, steps, and responsibilities.

The following details are frequently included in incident response planning:

- ✓ In most incident response plans; the following information is included:
- ✓ the incident response strategy of the company
- ✓ actions that must be completed during each phase of an incident response
- ✓ fulfilling IR activities duties and responsibilities
- ✓ Pathways of communication between the incident response team and the rest of the company
- ✓ parameters to measure how effective its IR capabilities are

It's important to remember that the value of an incident response plan doesn't end once a cyberattack has occurred; it continues to assist successful litigation, offer evidence for auditors,

Cybersecurity: Strategies and Best Practices

and provide past knowledge to input into the risk assessment process and enhance the incident response process itself.

IR is divided into four phases, according to the National Institute of Standards and Technology (NIST):

- **Preparation:** No organization can respond to a crisis effectively on the spur of the moment. It is necessary to have a plan in place to both prevent and respond to incidents.
- **Detection and analysis:** Identifying whether or not an incident occurred as well as the gravity and nature of the occurrence is the second stage of IR.
- **Containment and eradication:** The goal of the containment phase is to bring an incident's consequences to an end before they may do more harm.
- **Post-incident activities or Lessons learned phase:** After a large incident, lessons learned meeting involving all relevant stakeholders should be necessary, and after less serious incidents, it should be desirable, with the purpose of strengthening security in general and incident handling in particular.

Lesson-03: Security Operation Centers (SOC)

No matter where the assets are situated, a SOC serves as a central command post to gather information from the whole IT infrastructure of a business, including its networks, devices, appliances, and data stores. In some regions, businesses are required to alert the authorities if there is a cybersecurity breach. For all events logged within the monitored firm, the SOC essentially acts as a point of correlation. Each of these circumstances needs to be handled and managed by the SOC.

The SOC performs the following main functions.

1. Assess the available resources

The devices, processes, and applications that the SOC is tasked with defending, as well as the defensive tools at their disposal to help them do so, are divided into two groups.

✓ What the SOC Guards

Devices and data that are hidden from the SOC are unable to be protected. Without total device-to-cloud visibility, there may be security gaps in the network as a whole that can be identified and exploited. The goal of the SOC is to have a complete picture of the threat environment for the firm, which encompasses not just on-premises endpoints, servers, and software but also third-party services and traffic going across these assets.

✓ How Does the SOC Keep You Safe?

The SOC should also have a thorough awareness of all cybersecurity tools on hand as well as all SOC workflows. This increases the SOC's agility and helps it to perform at its best. Preparation and preventative maintenance are two of the most important steps in the process. When it

Cybersecurity: Strategies and Best Practices

comes to removing disasters in the first place, even the most well-equipped and speedy response systems fall short. To help keep intruders at bay, the SOC takes preventative measures that can be divided into two types.

✓ **Preparation**

Members of the team should stay up to date on the latest security innovations, cybercrime trends, and the emergence of new threats. This research can be used to assist in the development of a security roadmap for the firm's cybersecurity initiatives.

✓ **Maintenance as a preventative measure**

Members of the team should stay up to date on the latest security developments, cybercrime trends, and emerging risks. This research can be used to assist in the development of a cybersecurity roadmap for the firm.

2. Constant and Active Monitoring

Members of the team should stay up to date on the latest security developments, cybercrime trends, and new risks on the horizon. This research can be used to assist in the development of a security roadmap for the company's cybersecurity initiatives. A SIEM, EDR, or even better, a SOAR or XDR, are surveillance technologies that use behavioral analysis to "teach" computers the difference between routine day-to-day operations and true threat activity, minimizing the amount of triage and analysis necessary by humans.

3. Alert Management and Ranking

A SIEM or an EDR, or even better, a SOAR or an XDR, is a monitoring technology that uses behavioral analysis to "teach" computers the difference between routine day-to-day operations and true threat activity, minimizing the amount of triage and analysis necessary by humans.

4. Threat Reaction

The majority of people link these activities with the SOC. As soon as an incident is confirmed, the SOC takes immediate action, shutting down or isolating endpoints, stopping malicious programs (or preventing them from executing), deleting files, and so on. The goal is to respond to the extent necessary while minimizing the damage to the company's ability to continue operating.

5. Remediation and Recovery

These are the acts that most people associate with the SOC. As soon as an incident is confirmed, the SOC acts as a first responder, shutting down or isolating endpoints, halting malicious applications from executing, deleting files, and so on. The goal is to respond to the extent necessary while minimizing the disruption to the company's operations.

Cybersecurity: Strategies and Best Practices

6. Management of Logs

The SOC is in charge of creating, maintaining, and evaluating a log of all network activities and communications for the entire business. This information is helpful for creating a baseline for "normal" network activity, identifying hazards, and doing forensics and post-incident remediation. To combine and correlate data from apps, firewalls, operating systems, and endpoints—each of which generates its own logs—many security operations centers (SOCs) utilize a SIEM.

7. Conduct a root cause analysis

The SOC is responsible for identifying exactly what happened, when, how, and why after an occurrence. During this investigation, the SOC will use log data and other information to track down the root of the problem, assisting in the prevention of repeat incidents.

8. Refinement and Enhancement of Security

Cybercriminals are continually improving their tools and strategies, and the SOC must keep up with them by implementing upgrades on a regular basis. This step not only brings the Security Road Map's strategies to life, but it can also include hands-on techniques like red-teaming and purple-teaming.

9. Compliance Management

In many circumstances, the SOC's processes are guided by best practices, but others are governed by regulatory obligations. The SOC is in charge of regularly checking their systems to ensure that they are in compliance with any company, industry, or governmental standards. GDPR, HIPAA, and PCI DSS are just a few of these requirements. Following these principles protects the organization not only from the sensitive data entrusted to it but also from the reputational harm and legal worries that can arise as a result of a data breach.

Lesson-04: Security Information and Event Management

SIEM is a system that combines security information management (SIM) with security event management (SEM) to allow for real-time event monitoring and analysis, as well as security data tracking and logging for compliance and auditing.

Simply said, SIEM is a security solution that assists organizations in detecting possible security threats and vulnerabilities before they have a negative impact on their operations. It uses artificial intelligence to automate many of the human operations associated with threat identification and incident response. It has become a standard in modern security operation centers for security and compliance management use cases (SOCs).

Over time, SIEM has developed into something greater than earlier log management solutions. Because of AI and machine learning, SIEM can now do sophisticated user and entity behavior analyses (UEBA). For controlling risks that are continually changing as well as compliance and reporting, it is a potent data orchestration tool.

Cybersecurity: Strategies and Best Practices

What is SIEM and how does it work?

To identify threats and comply with data compliance regulations, all SIEM solutions do some amount of data collection, consolidation, and sorting at the most basic level. While some systems offer unique capabilities, the majority of them have the following essential characteristics:

1. Management of Logs

SIEM gathers data from several sources across an organization's network. Logs and flow data from users, applications, assets, cloud environments, and networks are collected, saved, and analyzed in real time, allowing IT and security teams to centrally manage their network's event log and network flow data.

Some SIEM solutions further connect to third-party threat intelligence feeds in order to compare their internal security data to recognized threat signatures and profiles. Teams can integrate with real-time threat feeds to block or find new types of attack signatures.

2. Analytics and Event Correlation

Event correlation must be a part of every SIEM solution. Event correlation delivers insights to swiftly detect and eliminate potential threats to corporate safety by using advanced analytics to uncover and evaluate specific data trends. SIEM solutions reduce the MTTD and MTR of IT security teams by offloading the manual processes necessary with thorough security event analysis (MTTR).

3. Security Alerts and Incident Monitoring

SIEM systems can identify all entities in the IT environment since they provide unified control of on-premise and cloud-based infrastructure. Then, SIEM technology can keep track of every connected user, device, and app for security flaws, spotting odd behavior as it occurs within the network. Administrators can be swiftly alerted and take appropriate action to mitigate the situation before it develops into more serious security risks using unique, specified correlation criteria.

Lesson-05: Threat Hunting

What exactly does threat hunting entail?

Threat hunting, also referred to as cyber threat hunting, is a proactive method of locating threats that were either unknown or unresolved within a company's network.

What use does threat hunting serve?

Threat hunting is crucial because sophisticated threats might evade automated cybersecurity. Although tier 1 and 2 security operations center (SOC) analysts and automated security solutions should be able to stop about 80% of threats, the other 20% need to be handled. Attacks that make up the remaining 20% are more likely to be sophisticated threats that can do considerable

Cybersecurity: Strategies and Best Practices

harm. They can enter any network, on average going undetected for up to 280 days, if they have the time and resources to do so. Threat hunting speeds up the process of finding a threat.

Attackers frequently remain undetected for weeks or even months. In order to get more access, they patiently wait for data to be siphoned off and sufficient personal information or credentials to be found, setting the stage for a big data breach. What kind of harm are you alluding to? A data breach costs a corporation, on average, USD \$4 million, according to the "Cost of a Data Breach Report 2020." The damaging effects of a breach might extend for years. The time between system failure and response deployment increases with the potential cost to a firm.

What is the threat-hunting procedure?

The basis of an effective campaign to find threats is the environment's data fecundity. Or to put it another way, a company must first establish an enterprise security system that collects data. Threat hunters might use the knowledge they learn from it to uncover crucial hints.

Cyber threat hunters bring a human element to corporate security, enhancing automated solutions. They are specialists in IT security who look for, log, monitor, and eliminate dangers before they can have a significant impact. They can be independent analysts, but they are typically internal IT security analysts who are familiar with the company's procedures.

Three different types of threat hunting:

1. Hunting with a plan

The indication of attack (IoA) and tactics, techniques, and procedures of an attacker serves as the basis for a planned search (TTPs). All hunts are organized and carried out in accordance with the TTPs of the threat actors. The Hunters, therefore, start their inquiry with a theory or a trigger. A more thorough investigation of potential risks is launched from the hypothesis or trigger. Systematic, unstructured, and situational hunting are all used in these more in-depth inquiries. Usually, it can identify a threat actor before the attacker has a chance to endanger the environment. This hunting type uses the MITRE Adversary Tactics, Techniques, and Common Knowledge (ATT&CK) framework in addition to the PRE-ATT&CK and enterprise frameworks (link outside of ibm.com).

2. Hunting without a plan

One of the many signs of compromise is when a trigger is used to start an unrestrained hunt (IoC). When this trigger is triggered, a hunter is frequently instructed to look for pre-detection and post-detection trends. To plan their strategy, the hunter can research as far back as data retention and previously connected offenses permit.

3. Situational or entity driven

An organization's internal risk assessment or analysis of the trends and vulnerabilities in a particular IT environment serves as the foundation for a situational hypothesis. Entity-oriented leads are obtained from attack data collected from the public, whose analysis shows the most

Cybersecurity: Strategies and Best Practices

recent TTPs of modern cyber threats. The surroundings can then be scanned by a threat hunter for these particular actions.

Lesson-06: Vulnerability Management

How does vulnerability management function and what is it?

The routine detection, assessment, reporting, management, and resolution of cyber vulnerabilities across endpoints, workloads, and systems is known as vulnerability management. A vulnerability management tool is frequently used by a security team to identify vulnerabilities, and there are several methods for patching or fixing them.

Threat intelligence and understanding of IT and business processes are used by a strong vulnerability management program to prioritize risks and address vulnerabilities as early as possible.

What's the Difference Between a Vulnerability, a Threat, and a Risk?

A vulnerability is "a weakness of an asset or collection of assets that may be exploited by one or more threats," according to the International Organization for Standardization (ISO 27002).

A threat is something that can take advantage of a weakness.

When a danger exploits a weakness, it creates a risk. It's the potential harm that an open vulnerability could produce if it's exploited by a threat.

The Process of Vulnerability Management

Vulnerability management programs should follow multiple steps in the vulnerability management process. While there are various ways to identify each stage of the cycle, the process remains largely the same, despite the differences in terminology.

Vulnerability Management Program Preparation

Before the process begins, Gartner's Vulnerability Management Guidance Framework lays out five "pre-work" steps:

- ✓ Step 1: Determine the Program's Scope
- ✓ Step 2: Establish Roles and Responsibilities.
- ✓ Step 3: Determine which Vulnerability Assessment tools to use.
- ✓ Step 4: Develop and refine policies and service level agreements (SLAs).
- ✓ Step 5: Determine the Sources of Asset Context

In order to discover gaps, this pre-work stage evaluates and measures present resources, procedures, and tools.

A security professional should ask questions like these during the pre-work phase to assist identify the scope of your program:

Cybersecurity: Strategies and Best Practices

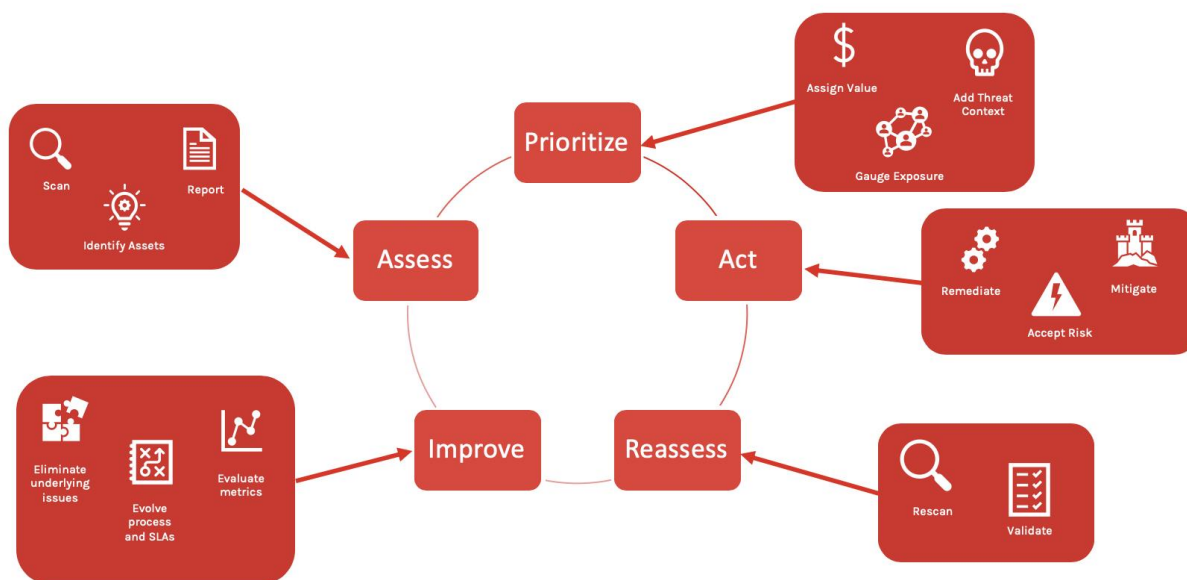
- ✓ Which assets will be scrutinized for flaws?
- ✓ Which assets or hosts are the most important to safeguard?
- ✓ Who is going to be in charge of this undertaking? What are their tasks and roles?
- ✓ How long do we have to fix a vulnerability after it's discovered? What policies or service level agreements (SLAs) must be established? How often should we check our assets for flaws or vulnerabilities?
- ✓ What tools or software do we need to administer or scan our hosts effectively?
- ✓ What assets from our asset types do we intend to cover? Or, to put it another way, what is the context of the assets we want to manage?

You can start implementing the vulnerability management approach with this information.

What are the Vulnerability Management Cycle's 5 Steps?

The vulnerability management cycle is divided into five stages:

- ✓ Step 1. Assess
- ✓ Step 2. Prioritize
- ✓ Step 3. Act
- ✓ Step 4. Reassess
- ✓ Step 5. Improve



Cybersecurity: Strategies and Best Practices

Module Three: Application Security

Lesson-01: API Security

What is API Security?

The process of preventing or mitigating attacks on APIs is known as application programming interface (API) security. APIs are the building blocks of mobile and online apps. As a consequence, it's critical to protect the sensitive data they submit.

An API is a software interface that determines how different pieces of software interact with one another. It regulates the kind of requests that are made between programs, how they are made, and what data formats are utilized. APIs are utilized in the Internet of Things (IoT) and website applications. They frequently collect and process data, or they allow the user to submit data that is processed within the API's context.

Google Maps, for example, is powered by an API. A web designer can include Google Maps on a page. When a user uses Google Maps, they are just using a prewritten API given by Google, rather than code that the web designer-built piece by piece. API security includes both your own APIs and those you use indirectly.

Why Web API Security Is Important

API security has grown increasingly critical, especially with the rise of IoT. Users, APIs, and the apps and systems with which they interact exchange critical and sensitive data. Hackers can use an insecure API to get access to a computer or network that is otherwise secure. Man-in-the-middle (MITM), distributed denial-of-service (DDoS), injection, and broken access control assaults are all possibilities.

REST API Security

The REST (representational state transfer) API security is one of the most popular API security options. You have a Hypertext Transfer Protocol (HTTP) Uniform Resource Identifier (URI) with REST API security, which restricts the data the API accesses while it runs. As a result, REST API security can prevent attacks containing harmful data that an attacker tries to introduce via an API.

How To Secure REST API

Secure sockets layer (SSL), transport layer security (TLS), and Hypertext Transfer Protocol Secure (HTTPS) protocols, which encrypt data during the transfer process, are all supported by REST API. Tokens can also be used to safeguard REST APIs, ensuring that communications are valid before allowing them to pass.

On the API level, security is implemented by inspecting the data that enters the API environment. API security inhibits attempts to cause the application to malfunction or to allow other users to get access and steal important information at the application level.

Cybersecurity: Strategies and Best Practices

REST API vs. SOAP API

The Extensible Markup Language (XML)-based Simple Object Access Protocol (SOAP) is a messaging protocol (XML). It's used to send data from one computer to another. It authenticates and authorizes messages by using XML signatures and Security Assertion Markup (SAML) tokens. It gives API keys in this way, preventing attackers from gaining access.

For the communication to pass through, the signatures and tokens must match the authorized formats. REST security differs from SOAP API security in that it does not require data routing and parsing. REST, on the other hand, takes advantage of HTTP requests and does not require data to be packed during transit.

Users could like SOAP over REST because it's simpler to build and use SOAP services across proxies and firewalls without modifying the original.

API Security Standards

Data security is critical, especially with the increase in data-driven projects. Following the API security recommended practices listed below is the best method to secure APIs.

Vulnerabilities

Understanding the threats in your system is the first step toward API security. You can hunt for specific vulnerabilities to detect weak points in the API lifecycle. For example, you can defend API backends by checking for signature-based attacks like SQL injections, using stricter rules for JavaScript Object Notation (JSON) routes and schemas, or using rate restrictions.

Tokens

Security tokens work by needing a token on each side of a communication to authenticate before it can continue. Because any application or user attempting to interact with the resource without the required token would be rejected, tokens can be used to restrict access to network resources.

Encryption

Encryption works by obscuring data at one end of communication and allowing it to be decrypted only if the correct decryption key is used at the other end. Otherwise, the encrypted data is a tangle of characters, numbers, and letters that makes no sense. Encryption contributes to API security by rendering data unreadable to unauthorized users whose devices are unable to decode it.

OAuth and OpenID Connect

The client-side application utilizes open authorization (OAuth) to acquire access tokens. OpenID Connect (OIDC) is an authentication layer that extends OAuth, enabling clients to verify the identity of end users. Both OAuth and OIDC enhance the levels of authentication and authorization by limiting information exchange to individuals who possess valid and verifiable tokens or appropriate identity credentials.

Cybersecurity: Strategies and Best Practices

Throttling and Quotas

Throttling and quotas protect bandwidth by restricting system access. DDoS attacks, for example, attempt to overload a system. Throttling reduces the speed at which data is delivered, thwarting an attack that relies on a constant barrage of data. Quotas limit the amount of data that can be transferred, preventing attacks that try to overload a system's processing resources with massive amounts of data.

API Gateway

An API gateway sits between the client and the backend's collection of services. It functions as a reverse proxy, authenticating traffic as it flows through it according to preset standards.

Zero-trust Approach

The zero-trust security model assumes that all traffic, whether it comes from within a network or from the outside, is untrustworthy. As a result, the user's privileges must be verified before traffic may be permitted to enter or exit the network. A zero-trust method can protect data and applications by prohibiting unauthorized users from gaining access to a system—this includes repeat users who may be impersonated by an impostor using a previously authenticated device. Both the user and the device are untrustworthy under a zero-trust scenario.

Lesson-02: Data-Flow Diagram

Data flow diagrams visually depict how data moves through an information system for businesses. DFD refers to the processes a system uses to move data from the input to file storage and report generation. Data flow diagrams visually depict how data moves through an information system for businesses. DFD refers to the processes a system uses to move data from the input to file storage and report generation.

Data flow diagrams are divided into two categories: logical and physical. The logical data flow diagram depicts the movement of data through a system in order to fulfill specific business functions. The physical data flow diagram shows how the logical data flow is put into action. The physical data flow diagram shows how the logical data flow is put into action.

What is the significance of DFD?

The functions or processes that collect, modify, store, and distribute data between a system and its environment, as well as between system components, are visually represented by the DFD. It's an effective means of communication between the user and the system. DFD's structure allows you to start with a broad overview and move down to a hierarchy of particular diagrams. Following are some uses of DFD that are common:

- ✓ The system's logical information flow
- ✓ Identifying the needs for the physical system's construction
- ✓ Notation simplicity
- ✓ Defining the needs for manual and automated systems

Cybersecurity: Strategies and Best Practices

DFD Symbols

A data-flow diagram can be represented using different symbols.

Process

A process takes in data and outputs data with different content or format. Processes might be as simple as gathering input data and recording it in a database, or as sophisticated as generating a report that contains monthly sales for all retail outlets in the northwest region. Every procedure has a name that describes the function it performs. The name is made up of a verb and a singular noun.

Example:

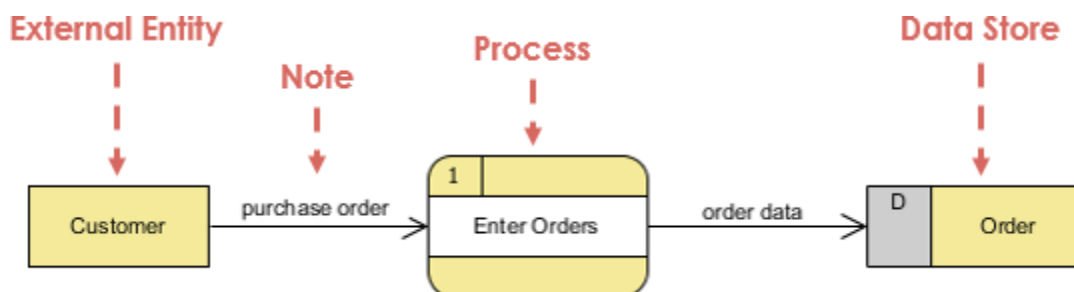
- ✓ Apply Payment
- ✓ Calculate Commission
- ✓ Verify Order

Notation

- ✓ A rounded rectangle represents a process
- ✓ Processes are assigned IDs for easier identification



Process Example



Lesson-03: Security QA

Cognizant offers a variety of security-related services, including vulnerability assessments for infrastructure and applications, safe SDLC assessments, and source code reviews. Security testing is carried out to compare the application/whole system to security standards (OWASP, OSSTMM, ISO 27001, and so on) and to assess risks and severity. It entails auditing and making recommendations for improvements.

There are four reasons why you should combine cyber security and quality assurance.

Cybersecurity: Strategies and Best Practices

Because of the following reasons, software cyber security and quality assurance should collaborate:

✓ **Reason #1: Security teams make QA teams' jobs easier, and vice versa.**

When security teams find threats and flaws in an application's software, they reduce hazards that could compromise the application's overall quality. They keep track of every move on the software that could expose it to threats and attacks. This risk management strategy allows QA teams to concentrate on increasing the security of a system.

✓ **Reason #2: It saves time and money**

You may reduce the time and expenses associated with cyber security and quality assurance methods by integrating them into the software development life cycle (SDLC) from the start.

The teams' collaboration, which begins at the start of the SDLC, will enable them to fix flaws and problems in the software early on. When the software is ready to use, it stops the difficulties from becoming more serious and unmanageable.

✓ **Reason #3: It produces dependable software.**

Because software with vulnerabilities is more vulnerable and susceptible to cyber-attacks, a security risk is also a QA issue. It's straightforward: poor code quality is a sign of the unpredictable nature of software.

A software performance problem or a flaw in the code could be to blame for the behavior. Attackers will therefore find it simple to exploit the software's flaws.

✓ **Reason #4: Software is more secure when cyber security and quality assurance are combined.**

Development teams are frequently focused on meeting deadlines and staying within budget limits. While this is a positive characteristic of development teams, they occasionally disregard security team advice.

Because the development teams' budgets and timelines are so tight, listening to the security requirements after a QA check seems unfeasible and useless. It does, however, have an impact on the software's security.

Cybersecurity: Strategies and Best Practices

Lesson-04: Security UX

UX design has made its way into the world of cybersecurity. The goal is to increase human stakeholder adoption of cyber capabilities, hence improving an organization's cyber health or providing a better secure experience to a consumer. At two levels of abstraction, micro, and macro, we can see UX design approaches implemented in cyberspace.

Micro practices: This is the type of thing we're used to seeing. While user experience design was not a priority during the days of command-line firewall configuration, it is now used in the following ways:

- **End-user applications:** Incorporating security into business/consumer apps that end-users engage with (e.g., single sign-on, simple multi-factor authentication) — in other words, a new security measure should not disrupt an employee's workflow.
- **Security technologies:** Creating a "single pane of glass" by combining tools through APIs and providing at-a-glance dashboards and well-visualized datasets.

Macro practices: Although the emphasis on the micro is essential, we have come to the stage where we must include UX design for bigger, more complicated cyber concerns. In order to better execute the cyber aim, a company's cyber strategy needs to win over the trust, increase its influence, and increase the number of stakeholders who have "skin in the game."

Examples of how UX design has been integrated into cyber strategy include:

- **Continuous capability refinement:** Consider how CI/CD works in terms of deploying code to production environments, and apply it to receiving capability feedback, building lessons learned, and fine-tuning your operationalized protect, detect, and respond functionality on a regular and frequent basis.
- **Operating model alignment:** Work to get to know your most critical stakeholders, imagine the unique experiences you want them to have, and plan how you'll keep them engaged with your cyber program resources.
- **Culture shaping:** You must design how people feel and perceive cybersecurity because "culture trumps strategy...so much that culture is strategy."

Lesson-05: Source Code Scan

Every piece of software and code contains flaws. While some of these issues are small and just affect the functionality of a program, others have the potential to jeopardize its security. Application security necessitates the detection and treatment of these potentially exploited security flaws.

When it comes to code scanning, developers and security teams have a variety of alternatives. The following are some of the most common vulnerability detection methods:

-  **Static Analysis:** Static application security testing is performed on an application's source code (SAST). By building a model of the application's execution state and using rules based

Cybersecurity: Strategies and Best Practices

on code patterns that lead to common faults, it finds application flaws (such as the use of unauthorized user input as a SQL query's input).

- ✚ **Dynamic Analysis:** To find vulnerabilities in a running application, dynamic application security testing (DAST) uses a library of known attacks and a fuzzer. DAST can uncover vulnerabilities in an application by exposing it to odd or malicious inputs and analyzing its responses.
- ✚ **Interactive Analysis:** Instrumentation is employed in interactive application security testing (IAST) to gain visibility into a program's inputs, outputs, and state during execution. Due to its visibility, it can identify abnormal application behavior during runtime that could be caused by the use of either well-known or newly discovered vulnerabilities.
- ✚ **Source Composition Analysis:** The majority of programs rely on a variety of third-party libraries and dependencies. SCA discovers an application's dependencies and examines them for known vulnerabilities that could compromise the application's security.

Lesson-06: S-SDLC

From conception to decommissioning, a software development life cycle (SDLC) provides a framework for the process of creating an application. Multiple SDLC models have emerged over time, ranging from the waterfall and iterative to agile and CI/CD, which increases the pace and frequency of deployment.

Most SDLCs comprise the following phases:

- ✓ Planning and requirements
- ✓ Architecture and design
- ✓ Test planning
- ✓ Coding
- ✓ Testing and results
- ✓ Release and maintenance

Previously, security-related activities were normally undertaken solely as part of testing—at the end of the SDLC. They wouldn't identify faults, flaws, and other vulnerabilities until they were significantly more expensive and time-consuming to address as a result of their late-game strategy. Worse, they wouldn't be able to uncover any security flaws at all.

In order to aid in the early discovery and reduction of vulnerabilities, essentially building security in, it is far better, not to mention quicker and less expensive, to include security testing throughout the SDLC as opposed to simply at the end. Architecture analysis during design, code review during coding and building, and penetration testing before release are a few examples of security assurance tasks. The following are a few of the most significant advantages of employing a secure SDLC strategy:

- ✓ Because security is a constant concern, your program is more secure.
- ✓ Security concerns are understood by all stakeholders.

Cybersecurity: Strategies and Best Practices

- ✓ Early detection of design flaws prevents them from becoming codified into reality.
- ✓ Because faults are detected and resolved early, you save money.
- ✓ Your company's overall underlying business risks are reduced.

Module Four: Physical Security

Lesson-01: IoT Security

IoT security is the process of finding, guarding, and monitoring hazards, as well as aiding in the repair of vulnerabilities from a number of devices, in order to secure Internet gadgets and the networks to which they're linked from attacks and breaches.

What are the Biggest Challenges with the Internet of Things Security?

It's critical to comprehend "what is IoT security" as well as the most pressing concerns facing IoT security. Because IoT devices were not designed with security measures in place, many device systems are insecure. In the great majority of cases, safety is paramount. They may also include malware that infects the network to which they are connected.

Some network security systems lack the capacity to detect IoT devices connected to the network, as well as the visibility to see what devices are communicating over it.

IoT and security requirements can only be satisfied by an integrated solution, such as a comprehensive security fabric approach, that offers visibility, segmentation, and protection across the whole network infrastructure.

The following critical capabilities must be present in your solution:

- ✓ **Learn:** Security solutions that have total network visibility may authenticate and classify IoT devices to create a risk profile and assign them to IoT device groups.
- ✓ **Segment:** Once a company is aware of its IoT attack surface, IoT devices can be categorized into policy-driven groups based on their risk profiles.
- ✓ **Protect:** Internal network segmentation and policy-driven IoT groups enable monitoring, inspection, and policy enforcement based on activity at various locations inside the infrastructure.

Lesson-02: Access Control

What is access control?

Because it decides who has access to and utilizes firm data and resources, access control is an important aspect of data security. Through authentication and authorization, access control rules guarantee that users are whom they indicate they are and have legitimate access to corporate data. Physical access to campuses, buildings, rooms, and data centers can also be restricted using access control.

Cybersecurity: Strategies and Best Practices

How does access control work?

To identify users, access control checks a variety of login credentials, including usernames and passwords, PINs, biometric scans, and security tokens. Many access control systems incorporate multifactor authentication (MFA), which requires various authentication methods to authenticate a user's identity.

Access control permits the proper amount of access and actions for a user when their credentials and IP address have been confirmed. Four categories can be used to categorize access control. Typically, organizations select the solution that best meets their unique security and compliance requirements. The following are the four access control models:

1. **Discretionary access control (DAC):** The policy governing who is granted access is set by the owner or administrator of the protected system, data, or resource in this way.
2. **Mandatory access control (MAC):** People are provided access based on an information clearance in this nondiscretionary paradigm. Access privileges are regulated by a central authority depending on different security levels. In government and military situations, this paradigm is commonly employed.
3. **Role-based access control (RBAC):** RBAC gives access based on established business functions rather than the identification of each individual user. The idea is for people to have access to only the data that is required for their positions within the company. A complicated combination of role assignments, authorizations, and permissions is used in this frequently used system.
4. **Attribute-based access control (ABAC):** Access is given based on a number of characteristics and environmental factors that are applied to both individuals and resources, such as location and time of day.

Lesson-03: Social Engineering

The practice of convincing people to provide personal information is known as social engineering. The data that these criminals are after varies, but if you pay attention, they're probably trying to trick you into giving them your user credentials or bank account information, or into giving them access to your computer so they can covertly install malicious software that will give them control over your computer as well as access to your passwords and bank account information.

Criminals use social engineering because it is frequently simpler to take advantage of your innate desire for trust than to figure out how to hack your program. For instance, convincing someone to give you their password is much simpler than attempting to hack it (unless the password is really weak).

Cybersecurity: Strategies and Best Practices

What Signs Point to Social Engineering Attacks?

Email from a friend

Because most people use the same password across all of their accounts, if a criminal can crack someone's email password or socially engineer it, they will have access to that person's contact list and almost definitely their social networking contacts as well.

Once the criminal has access to the email account, they can publish messages on all of the victim's friends' social media pages as well as the pages of their friends' friends or send emails to all of the victim's contacts.

These messages will profit from your confidence and interest to:

- **Contain a link** that you feel compelled to check out. Because the link is from a friend and you are curious, you will click on it out of trust. This will infect your computer with malware, allowing the criminal to take control of it, gather the personal data of your contacts, and deceive them in the same way that you were tricked.
- a photo, piece of music, movie, document, or another download that has a harmful virus implanted in it. You will catch the disease if you download it, which is what you would probably do since it seems to be coming from a friend. Having gained access to your computer, email, social media accounts, and contacts, the thief is now attacking everyone you know. The list keeps going forever.

Email from a different reliable source

Phishing is a form of social engineering that impersonates a reliable source and fabricates a scenario where a victim would be persuaded to divulge critical personal information like login passwords. The vast majority of impersonated businesses are financial organizations, according to Webroot data, while social engineering attacks like phishing and pretexting (see below) account for 93 percent of successful data breaches, according to Verizon's annual Data Breach Investigations Report.

Baiting scenarios

These social engineering techniques are aware that many individuals will bite if you provide them with what they want. On peer-to-peer networks that offer a download of something popular, like a new movie or song, these kinds of schemes are common. On the other side, scammers can be found on shady websites that can be reached through search results, social networking sites, and so forth.

Fraud victims run the risk of losing money without receiving the requested item, having their bank account empty if they paid by check, and becoming infected with malicious software that can generate a variety of new vulnerabilities against them and their connections.

Cybersecurity: Strategies and Best Practices

Answer to a question you didn't ask

Criminals may offer more assistance while imitating a company's answer to your request for aid. They pick companies that serve millions of customers, such as banks or software companies. If you don't use the product or service, you'll probably disregard the email, phone contact, or message; however, if you do, there's a good chance you'll answer since you're presumably looking for assistance with a problem.

For instance, even if you didn't ask a question, you surely have a problem with the operating system on your computer and you take advantage of this chance to fix it. without expense! As soon as you respond, you have accepted the thief's account, given them your faith, and give them your money.

Lesson-04: Physical Security System Components

The modern business owner is confronted with security issues at every turn. Due to technological improvements, threats can now come from practically everywhere, making physical security more crucial than ever. Physical hazards should not be disregarded, even if many firms focus on their security and hacking activities. Every breach, no matter how small, has an effect on your business, from financial losses to a damaged reputation to the unease your employees feel at work. The correct physical security measures could make all the difference in protecting your business and data, even for small organizations.

Before discussing the numerous elements and planning considerations, let's first define physical security. Physical security measures are designed to maintain the safety and security of buildings while safeguarding the equipment inside. In a nutshell, they permit authorized people to in while keeping undesirables out. Physical security breaches and threats must be avoided in order to protect your technology and data as well as any staff or faculty members who have access to the facility. Network and cybersecurity are important, but they cannot be taken for granted. If you lack physical security policies, your office or facility will be open to criminal behavior. Concerns about physical security include burglary, vandalism, fraud, and even accidents.

Physical security control examples in the built environment include locks, gates, and guards. While these are useful, there are many more layers of physical security for offices that are sometimes overlooked and can assist secure all of your valuables. A complete physical security plan incorporates both technology and specialized hardware, as well as anti-intrusion techniques such as:

- Layout and design of the website
- Environmental factors
- Preparedness for an emergency
- Training
- Access control
- Intrusion detection

Cybersecurity: Strategies and Best Practices

- Protection from electricity and fire

Lesson-05: Security Personnel

Roles of the Cyber Security Professional

The best level of protection for IT infrastructure, edge devices, networks, and data must be provided by cybersecurity professionals. They accept responsibility for preventing data breaches, keeping track of security breaches, and responding to them.

Cyber Security Professional's Responsibilities

New security threats develop on a daily basis, and IT security professionals must stay up with the latest hacking tactics. IT security teams also do the following duties in addition to the high-level functions stated above:

- ✓ Set up and utilize user access controls, as well as identity and access management systems.
- ✓ Keep an eye on network and application performance to detect and avoid aberrant behavior.
- ✓ Conduct frequent audits to verify compliance with security protocols.
- ✓ Use endpoint detection and prevention tools to stop harmful attacks.
- ✓ Set up patch management systems to update software automatically.
- ✓ Implement comprehensive vulnerability management solutions across all assets, including on-premises, and in the cloud.
- ✓ Set up a catastrophe recovery/business continuity strategy in collaboration with IT operations.
- ✓ In coordination with HR and/or team leads, train employees on how to recognize suspicious behavior.

Module Five: Threat Intelligence

Lesson-01: What Is Threat Intelligence?

In today's interconnected digital world, organizations face an ever-present and evolving threat landscape of cyberattacks. To effectively combat these risks, it is essential to understand and utilize threat intelligence. Threat intelligence refers to the collection, analysis, and dissemination of data that helps organizations prevent, detect, and respond to potential threats.

Threat intelligence goes beyond raw data; it provides context and insights that enable organizations to make informed security decisions. It answers crucial questions, such as who is attacking, what their motivations and capabilities are, and what signs of system penetration to look for. By leveraging threat intelligence, organizations can proactively strengthen their security posture and stay ahead of adversaries.

Cybersecurity: Strategies and Best Practices

Lesson-02: Who Benefits from Threat Intelligence?

Everyone! Elite analysts are frequently regarded to be in charge of cyber threat intelligence. In reality, it benefits security functions across the board for companies of all sizes.

Many of the individuals who may benefit the most from threat intelligence don't have access to it when they need it because it's seen as a distinct function within a wider security paradigm rather than an essential component that complements all other activities.

Threat intelligence comes into contact with your existing security systems, automatically emphasizing and sorting alerts and other risks. Security operations teams are frequently unable to handle the signals they receive – threat intelligence interacts with your existing security systems, automatically prioritizing and filtering alerts and other risks. Vulnerability management teams may more accurately prioritize the most serious weaknesses with access to threat intelligence's external insights and context. Threat intelligence provides valuable insight into threat actors, their techniques, methodologies, and guidelines, as well as other high-level security operations, such as fraud protection, risk evaluation, and other strong security processes.

Lesson-03: Threat Intelligence Lifecycle

So, where do we get our cyber threat intelligence? The final result of a six-part cycle of data collection, processing, and analysis is cyber threat intelligence; raw data is not the same as intelligence. This is a circle because as intelligence develops, new challenges and information gaps occur, prompting the construction of new collection requirements. Iterative intelligence means that software improves with time.

Planning and Direction

The first step in obtaining actionable threat intelligence is to ask the proper questions.

Inquiries that focus on a single fact, event, or behavior are preferable for generating actionable threat intelligence; broad, open-ended questions should be avoided in most circumstances. Prioritize your intelligence goals depending on how well they connect with your company's fundamental values, the extent of the decision's effect, and the decision's timeliness.

Collection

The second step entails gathering raw data that satisfies the standards of the first. It's best to collect data from several sources, including internal sources like network event logs and past incident response records, as well as external sources like the open web, the dark web, and technical sources. Threat data is typically thought of as a list of indicators of compromise (IoCs), such as malicious IP addresses, domains, and file hashes, but it can also comprise vulnerability information, such as personally identifiable information from customers, raw code from paste sites, and text from news outlets or social media.

Cybersecurity: Strategies and Best Practices

Processing

After you've acquired all of the raw data, sort it, organize it using metadata tags, and filter out any redundant data or false positives or negatives. Even small firms collect millions of log events and hundreds of thousands of indicators per day. It's too much for human analysts to handle in a timely manner; data collection and processing must be automated before any conclusions can be drawn.

Examine

The next step is to interpret the data that has been gathered. Finding potential security issues and alerting the appropriate teams in a manner that satisfies the intelligence criteria defined during the planning and directing stage are the objectives of the analysis. Getting the data into a format that the audience can understand depends on the initial goals and intended audience and can take many different shapes. Simple threat lists for peer-reviewed works are an example.

Publication

After that, the final product is supplied to the designated customers. Threat intelligence must reach the appropriate individuals at the appropriate time in order to be useful.

It must also be tracked to ensure that learning does not lapse when one intelligence cycle gives way to the next. Whenever a new intelligence demand develops, use ticketing systems that integrate with your existing security systems to monitor each stage of the intelligence cycle - tickets may be submitted, written up, analyzed, and finished by several employees from various teams, all in one place.

Provide feedback

And, the final step is to provide feedback.

Lesson-04: Threat Intelligence Use Cases

Threat intelligence is a valuable resource for cross-functional teams in any organization because of its wide range of applications. Threat intelligence is important in triage, risk analysis, vulnerability management, and wide-scope decision-making, and it's likely the most instantly effective when it helps you avert an attack.

1. Response to an Incident

Security analysts in charge of incident response are among the most stressed in the industry, and it's easy to see why: the number of cyber-attacks has gradually increased over the last two decades, and a large percentage of daily alerts are false positives. When dealing with real-life occurrences, analysts are frequently forced to spend time manually going through data in order to analyze the situation.

Cybersecurity: Strategies and Best Practices

2. Operational Security Operational Security

The majority of security operations centers (SOCs) have to deal with massive amounts of warnings issued by the networks they monitor. It takes too long to triage these notifications, and many of them are never looked into. Analysts suffer from "alert fatigue," which causes them to take notifications less seriously than they should. Many of these issues are addressed by threat intelligence, which aids in the gathering of threat information more quickly and precisely, the filtering of false alarms, the speeding up of triage, and the simplification of event analysis. Analysts can no longer waste time chasing down alerts based on:

- ✓ Actions that are more likely to be harmless than malicious.
- ✓ Attacks that have nothing to do with the company
- ✓ Attacks that already have defenses and restrictions in place

3. Management of Vulnerabilities

Effective vulnerability management entails moving away from the impossible-to-achieve "patch everything, all the time" approach to prioritizing vulnerabilities based on actual risk.

Research indicates that the bulk of assaults target the same, small set of vulnerabilities, despite the fact that the number of threats and vulnerabilities increases every year. Threat actors are also operating more quickly given that the average time between the disclosure of a new vulnerability and the appearance of an exploit utilizing it is only fifteen days.

4. Preventing Fraud

It's not enough to just detect and respond to attacks that are already exploiting your systems to keep your company safe. You must also guard against unauthorized usage of your data or brand.

Threat intelligence obtained from underground criminal communities can provide insight into threat actors' objectives, methods, and tactics, especially when combined with data from the surface web, such as technical feeds and indicators.

Lesson-05: Types of Threat Intelligence

Cyber threat intelligence is one of the main pillars of cybersecurity strategies (CTI). CTI is one of the most important tools for incident prevention, detection, and reaction to breaches even though it is not the solution to all cybersecurity issues.

Three categories are typically used to categorize threat intelligence:

1. **Strategic:** popular trends among non-technical audiences.
2. **Tactical:** For a more technical audience, describe the tactics, strategies, and procedures used by threat actors.
3. **Operational:** technical information about certain campaigns and assaults. Operational indicators are compiled using data provided by third parties, active campaigns, and honeypot attacks.

Cybersecurity: Strategies and Best Practices

Module Six: Risk Assessment

Lesson-01: What Is Cyber Risk?

The probability that your business will be subject to a cyberattack or data breach and suffer financial loss is referred to as cybersecurity risk. The potential loss or damage to an organization's technological infrastructure, technology use, or reputation constitutes a larger, more inclusive definition.

Due to their increasing reliance on computers, networks, software, social media, and data, businesses all over the world are becoming more and more exposed to cyber dangers. Data breaches, a common cyber-attack, frequently result from inadequate data security and have a significant negative impact on enterprises.

Because of greater worldwide connectivity and increased use of cloud services with lax default security measures, there is an increased risk of cyberattacks from outside your company. Advanced cyber security specialists, software, and cybersecurity risk management are now required, in addition to proper IT risk management and access control.

It's no longer sufficient to rely on conventional IT staff and security processes for information security. There is no doubt that your firm needs threat intelligence tools and security programs to reduce its cyber risk and reveal potential attack surfaces.

Decision-makers must undertake risk assessments, have a risk mitigation strategy in place, and have a cyber incident response plan in place in the case of a breach before prioritizing third-party providers.

Lesson-02: What Is a Cyber Risk Assessment?

A cybersecurity risk assessment examines the many information assets (such as hardware, systems, laptops, customer data, and intellectual property) that could be impacted by a cyberattack as well as the various hazards that could have an effect on them.

In the realm of cybersecurity, staying ahead of potential risks is crucial for organizations to protect their information assets and maintain a robust security posture.

Actually, a cyber risk assessment is a systematic and comprehensive evaluation of the potential risks and vulnerabilities that an organization's information assets may face due to cyberattacks or other hazards. It involves assessing the impact and likelihood of various threats and identifying appropriate controls to manage and mitigate the identified risks effectively. By conducting a cyber risk assessment, organizations gain insights into their risk landscape and can make informed decisions regarding risk management and resource allocation.

Cybersecurity: Strategies and Best Practices

Lesson-03: What Problems Does a Security Risk Assessment Solve?

A thorough security assessment can be used by an organization to:

- Identify the resources of the company (e.g., network, servers, apps, data centers, tools, etc.).
- Create a risk profile for each asset.
- Find out more about the data that these assets generate, store, and transfer.
- Identify the asset's worth in terms of how the business operates. This speaks to a company's total effect on sales, standing, and vulnerability to exploitation.
- Assess assets by calculating their risk score and ranking them in order of importance for appraisal.
- Implement mitigating controls for each asset in accordance with the findings of the assessment.

It's crucial to understand that a security risk assessment is a continuous process. Instead, it should be performed continuously at least twice a year. An organization can see the hazards and dangers to which it is susceptible in real time thanks to a continuous evaluation.

Synopsys advises annual evaluations of significant assets with a higher potential impact and risk. A vast amount of helpful data is generated and gathered during the assessment process. Here are a few illustrations:

- Create a portfolio of all your current apps, utilities, and tools.
- Rules, procedures, and security requirements must all be documented.
- Assemble a database of system designs, network layouts, data saved or transmitted by the system, and contacts with other suppliers or services.
- Make an inventory of tangible assets (e.g., hardware, network, and communication components and peripherals).
- Operate system information must be maintained current (e.g., PC and server operating systems).

The following information:

- ✓ collection of data (e.g., database management systems, files, etc.).
- ✓ current security measures (e.g., authentication systems, access control systems, antivirus, spam controls, network monitoring, firewalls, intrusion detection, and prevention systems).
- ✓ Current minimum security and operational requirements for regulatory bodies' adherence.
- ✓ threats, weaknesses, and resources (including their impacts and likelihood).
- ✓ previous technical and procedural examinations of the network system, policies, and applications
- ✓ Each risk that is found for an asset generates a map of mitigating controls.

Cybersecurity: Strategies and Best Practices

Small firms may not have the resources in-house to conduct a full assessment, necessitating the involvement of a third party. Cybersecurity software is also being used by businesses to track their security score, prevent breaches, distribute security questionnaires, and reduce third-party risk.

Lesson-04: How to Perform a Cyber Risk Assessment?

An efficient cybersecurity evaluation may vary from company to company depending on their industry or the local laws in their region, but the fundamentals remain the same. Keep the following in mind when doing a cybersecurity assessment:

1. Determine the assessment's scope.

Determine the full scope of the cybersecurity assessment by identifying all assets that will be reviewed. Instead of tackling everything at once, you might want to start by focusing on one sort of asset at a time. Once you've decided on an asset type, you'll need to figure out what other assets, devices, or information it interacts with. This will ensure that you get a complete picture of your entire network.

2. Determine the worth of each asset

You'll need to find out how much each item is worth after you've determined which assets will be included in the appraisal. It's important to keep in mind that an asset's true value could be higher than its acquisition price. Intangible elements and qualitative hazards connected with each asset must be considered during the appraisal process.

3. Recognize cybersecurity threats

Identifying cybersecurity risks is the next step in a cybersecurity assessment so you can estimate the possibility of different loss scenarios and make future decisions with knowledge. Think about the several scenarios in which the asset might be used, the likelihood of exploitation, and the overall effect of the use of the asset on your company. This is a crucial step in ensuring that your business complies with any cybersecurity requirements that may be applicable to your industry.

4. Evaluate the asset's worth against the cost of prevention.

You must evaluate the asset's value to the cost of protecting it after determining its value. Determine whether the expense of preventing such accidents is greater than the asset's value. If so, it's probably worth considering an alternative control or preventative technique that makes more financial sense.

5. Install and monitor security controls on a regular basis.

Following the identification and analysis of essential assets and vulnerabilities within your organization's network, the following stage is to put in place security mechanisms that can continuously monitor your network's cybersecurity. This will ensure that the controls in place continue to meet organizational needs and secure critical information.

Cybersecurity: Strategies and Best Practices

Module Seven: Enterprise Risk Management

Lesson-01: What Is Enterprise Risk Management (ERM)?

Enterprise risk management (ERM) is the systematic process of detecting and resolving potential occurrences that pose a threat to achieving strategic goals or possibilities for competitive advantage.

Every organization's strategic management should include risk management as a vital component. It should be ingrained into daily operations. Two frequently used frameworks include the "ERM - Integrated Framework" created by the Committee of Sponsoring Organizations of the Treadway Commission COSO and the "A structured approach to ERM and the requirements of ISO 31000" guidelines created by Airmic and the Institute of Risk Management IRM.

The pillars of ERM are the evaluation of significant risks and the implementation of effective risk solutions. Risk reactions include risk acceptance or tolerance, risk avoidance or termination, transfer of risk or sharing via insurance, a joint venture, or other arrangements, and risk reduction or mitigation via internal control systems or other risk-prevention measures.

ERM ideas like as risk philosophy or risk strategy, risk culture, and risk appetite are all important. These are expressions of the organization's risk mindset and willingness to accept risks. These are important components of government transparency.



Cybersecurity: Strategies and Best Practices

Lesson-02: Why Is Cybersecurity Important to Enterprise Risk Management?

It's crucial to realize that cybersecurity is a risk to be managed rather than a problem to be solved. In the digital age, cyber risk is now a concern for the entire company, not just the tech or IT department. By considering risks from a business perspective, executives can make decisions that consider both protection and operational performance.

You must first understand the implications of each cyber risk before you can evaluate the threats that an organization faces. You can more effectively prioritize risks and the next steps by integrating relevant business context in cyber risk assessments. As businesses become more reliant on technology for day-to-day operations, cybersecurity has become critical to enterprise risk management.

ERM not only needs businesses to evaluate all risks they face and determine which risks to effectively monitor (as other forms of risk management do), but it also enables top executives to make executive risk management decisions that may or may not be in the best interests of a specific segment—but are best for the company overall. This is because hazards may be compartmentalized in specialized business units that are unable or unwilling to see the larger picture.

It also typically requires presenting the risk action plan as part of an annual report to all stakeholders. Aviation, construction, public health, international development, energy, banking, and insurance are just a few of the businesses that have adopted ERM.

Businesses have been using risk management for a long time. Risk management has always been based on each business unit analyzing and controlling its own risk before reporting to the CEO. Recently, businesses have begun to see the necessity for a more complete plan.

Lesson-03: Crisis Management

A cyber crisis is handled in the same way that any other crisis is handled. In order to detect a cybercrime-related occurrence, it is necessary to anticipate dangers. The crisis unit must then be activated and the cleanup processes must be carried out. The feedback analysis and design of a new cyber crisis management policy round out the crisis management process.

How do you spot a cyber crisis?

Cyber crises are often difficult to spot. Except in the case of a denial-of-service assault, which has immediate implications, the IT department usually does not detect a cyber-attack until it has already occurred, when it has already badly compromised data security, for example.

Cybersecurity: Strategies and Best Practices

What are the ramifications of a cyber-attack?

A cyber-attack can bring your computer systems to a halt or lead to the theft of important data. It may put you at risk of blackmail, or it may harm your reputation and, as a result, your financial worth.

Lesson-04: Cyber Insurance

A cyber insurance policy, often known as "cyber risk insurance" or "cyber liability insurance," is a financial instrument that allows companies to defer the costs of recovering from a cyber-related security breach or other comparable incidents.

The most important aspect of cyber insurance is typically the coverage for network security. If a network security incident occurs, such as a data breach, malware infection, ransomware attack, compromised corporate account, or compromised email, this coverage will respond. On the other hand, liability claims and additional expenses incurred as a result of an assault or breach will be compensated.

A panel of top breach coaches and other service providers may also be accessible under certain circumstances according to the policy.

Cyber insurance is not standardized because it is as dynamic as the companies it protects. However, the following topics are frequently covered by cyber liability insurance:

- ✓ Data loss, recovery, and recreation are all things that can happen.
- ✓ Due to a breach, there is a risk of business interruption and income loss.
- ✓ Transferred monies are lost.
- ✓ Computer thievery
- ✓ Extortion via the internet

Cyber liability insurance provides the following protections in the event that hackers leak or steal personal data, including Social Security numbers, driver's license numbers (in some states), addresses, and bank account information:

-  **Costs of Notification:** This is a major cost because the corporation is responsible for both identifying prospective victims (which necessitates an internal investigation) and providing notification that is reasonably assessed to provide actual notice.
-  **Credit Monitoring:** Your cyber insurance policy, in effect, pays for the insurance policies of the victims. Typically, regulators determine the type of credit monitoring to be provided, and it's a fair bet that they won't be content with the lowest option.
-  **Civil Damages:** The majority of these liability claims are class actions, with damages in the hundreds of thousands of dollars, even for a tiny business.
-  **Computer Forensics:** This covers the costs of hiring computer forensics professionals to determine whether a data breach happened, to control and prevent future harm, and to investigate the source and scope of the incident under the guidance of your attorneys.

Cybersecurity: Strategies and Best Practices

- ✚ **Damage to a company's reputation:** A data breach can have serious consequences for a company's reputation. A recommended policy will assist you in dealing with the potential consequences by covering damages resulting from brand aversion as a result of a cyber incident for a set period of time following the breach. Paying for PR management specialists can also help to reduce possible expenses.

Lesson-05: Line of Defense

Cyber Security Professionals Have 3 Lines of Defense

The IIA created the "3 Lines of Defense" plan for improved risk management in the wake of the financial crisis. Regulators can better evaluate the risks in the financial industry thanks to this methodology. Although the approach was developed primarily for financial services, it is frequently used to the subject of cyber security. Here is an overview of the three LoD models' roles and responsibilities in relation to cyber security, without further ado.

The first line of defense is also known as an organization's operational management. All front-line managers are in charge of implementing controls, formulating policies, managing day-to-day risks, and ensuring that policies are reinforced by relevant procedures that employees may use in their BAU tasks. For example, the first line of defense is implemented while complying with the SOX 404 standard, often known as Internal Controls Over Financial Reporting (ICFR). Implementing adequate Segregation of Duties, information security policies, and conducting penetration testing are examples of this control.

Risk Monitoring and Oversight - The 2nd Line of Defense is also known as Risk Monitoring and Oversight. The second line of defense supervises the first line of defense's controls and performs risk monitoring on a regular basis. The second LoD is usually reserved for information security and risk management. These functions of monitoring and oversight guarantee that controls are appropriately designed and functioning.

The 3rd Line of Defense is the last line of defense. The 3rd LoD is the Audit function, which should ideally be independent of the 1st and 2nd LoD's effect. The 3rd LoD is responsible for overseeing the duties of both the 1st and 2nd LoDs. Internal and external auditors are typically the two audit teams.

Internal auditors evaluate control frameworks on a regular basis to ensure that they are functioning effectively and are appropriate for the organization's present risk posture. These groups are in charge of conducting their own independent testing by selecting a sample of the population based on its size.

Cybersecurity: Strategies and Best Practices

Lesson-06: Risk Treatment Actions

The process of identifying and executing risk-reduction strategies is referred to as risk treatment. Risk treatment strategies include avoiding, optimizing, transferring, and maintaining risk. The measures (security measurements) can be picked from a list provided by the organization's Information Security Management System (ISMS).

Security measures at this level are linguistic explanations of various security operations carried out either technically (using software or hardware components, for example) or organizationally (e.g., established procedures).

Despite the fact that risk management in ISO 27001 is a complicated task, it is frequently misunderstood. The following six fundamental stages will help you figure out what you need to do:

1. Risk assessment approach according to ISO 27001

Your journey toward ISO 27001 risk management begins here. You'll need to lay out the rules for how you'll manage risk because you want your entire organization to follow them. The biggest issue with risk assessment is when it is carried out inconsistently across the company. You must therefore decide if you want a qualitative or quantitative risk assessment, the scales to use for the qualitative evaluation, and the level of risk that is acceptable.

2. Implementation of risk assessment

Once you understand the rules, you can begin determining which potential problems may affect you – you must first list all of your assets, then the risks and vulnerabilities associated with those assets, and evaluate the effect and likelihood of each asset/threat/vulnerability combination, and lastly compute your risk level.

Companies, in my experience, are frequently only aware of 30% of their risks. As a result, you'll likely find this type of workout incredibly enlightening — once you've completed it, you'll begin to realize the effort you've put in.

3. Implementation of risk treatment

Of course, not all risks are created equal; you must concentrate on the most critical, or "unacceptable risks."

4. Report on Risk Assessment and Treatment

This phase, unlike the others, is tedious: you must document everything you've done so far. This isn't only for the auditors; you might want to double-check these numbers in a year or two.

5. Affirmation of Applicability

This document depicts your company's security profile; you must list all the controls you have installed, why you implemented them, and how you applied them, based on the results of the

Cybersecurity: Strategies and Best Practices

risk treatment in ISO 27001. This document is particularly crucial since it will serve as the major guideline for the certification auditor during the audit.

6. Risk Management Strategy

This is the point at which you must transition from theory to practice. To be honest, this entire risk management job has been totally theoretical up until now, but now it's time to show some tangible outcomes.

This is the goal of the Risk Treatment Plan: to specify who will apply each control when they will do it, and on what budget. I'd like to refer to this document as an "Implementation Plan" or "Action Plan," but let's keep to the ISO 27001 language.

And that's it; you've gone from having no idea how to set up your information security to having a very clear understanding of what you need to do. The point is that ISO 27001 forces you to take a methodical approach to this process.

What is ISO 27005's role in risk management?

The ISO/IEC 27005 standard is only concerned with the management of information security risks. It is extremely beneficial if you want to gain a better understanding of information security risk assessment and treatment - in other words if you want to be an information security/risk management permanently or even as a consultancy.

If you only want to undertake risk assessments once a year, however, that criterion is generally not essential.

Conclusion

In our continuously changing digital environment, cybersecurity is essential. Organizations must design a vulnerability management life cycle, promote employee awareness, and deploy strong security measures. Systems and data are protected by robust encryption, frequent software updates, multi-factor authentication, and security assessments. Organizations build a robust human firewall by teaching employees about prevalent dangers and equipping them to recognize and report suspicious activity. To keep one step ahead of attackers, organizations and security professionals must cooperate and share information. Organizations must maintain vigilance, adjust security policies, and stay up to date on trends and best practices as long as cybersecurity challenges persist. We can safeguard our crucial data and systems by proactively guarding against cyberthreats.